

Clase 150 — Ransomware: anatomía y análisis

Parte: **6 — Análisis de malware** · Fuente: *Learning Malware Analysis* (Monnappa) y The DFIR Report 

Duración estimada: **130 min** · Nivel: **Avanzado**

Objetivo

Disecionar la familia de mayor impacto económico actual: el ransomware. El alumno analizará su cadena completa (acceso, escalada, movimiento, exfiltración y cifrado), estudiará el esquema criptográfico, evaluará si el descifrado es posible sin la clave y extraerá IOCs y TTPs para prevención y respuesta.

Resultados de aprendizaje

Al finalizar, el alumno podrá:

1. **Describir** la cadena de ataque de un incidente de ransomware moderno.
2. **Analizar** el esquema de cifrado (simétrico/asimétrico, generación de claves).
3. **Evaluar** la posibilidad de recuperación sin pagar (errores de implementación, backups).
4. **Identificar** la doble extorsión y la exfiltración previa al cifrado.
5. **Extraer** IOCs, nota de rescate y TTPs para detección y respuesta.

Temas

#	Tema	Por qué importa
1	Cadena de ataque (RaaS)	El cifrado es la última fase, no la única
2	Esquema criptográfico	Determina si hay recuperación posible
3	Enumeración y cifrado de archivos	Comportamiento característico
4	Borrado de shadow copies / backups	Impide recuperación local
5	Doble extorsión y exfiltración	Presión adicional sobre la víctima
6	Nota de rescate y branding	Atribución de familia
7	Prevención y respuesta	Backups, segmentación, detección temprana

Definiciones y características

- **RaaS (Ransomware-as-a-Service):** modelo con operadores y afiliados. Característica clave: **división del trabajo**.
- **Cifrado híbrido:** clave simétrica por archivo protegida con clave pública. Característica clave: **rápido + irrecuperable sin la privada**.
- **Shadow copies:** copias VSS de Windows. Característica clave: el ransomware **las borra** (`vssadmin delete shadows`).
- **Doble extorsión:** exfiltrar datos antes de cifrar. Característica clave: **chantaje con filtración**.

- **Nota de rescate:** instrucciones de pago. Característica clave: **firma de familia**.

Herramientas y preparación

- **ProcMon/Process Hacker, Wireshark, Volatility** para comportamiento.
- **Ghidra/x64dbg** para el módulo de cifrado.
- **PEStudio/capa** para detectar APIs de cripto (`CryptGenKey` , `CryptEncrypt` , `BCrypt`).
- Referencias: **No More Ransom**, informes de The DFIR Report.

 **Nota ética y de seguridad:** el ransomware **cifra datos**; ejecútalo solo en la VM aislada con snapshot y sin acceso a carpetas compartidas del host. Restaura `base-clean` inmediatamente después. Nunca lo pruebes en un sistema con datos reales ni en red corporativa.

Laboratorio guiado

1. Restaura `base-clean` . Crea archivos señuelo (`.docx` , `.txt` , `.jpg`) en carpetas de usuario para observar el cifrado.
2. Analiza estáticamente: con `capa` /PEStudio identifica APIs de cripto y enumeración de archivos (`FindFirstFile` , `CryptEncrypt`).
3. Detona con ProcMon filtrando por `CreateFile` / `WriteFile` : observa el patrón de recorrido de directorios y la escritura de archivos cifrados (nueva extensión, marcador de cabecera).
4. Busca el borrado de recuperación: `vssadmin delete shadows` , `wbadmin` , `bcdedit` . Anótalo como TTP (`T1490`).
5. En Wireshark, comprueba si hay contacto C2 o exfiltración previa al cifrado (doble extorsión).
6. En Ghidra, localiza el módulo de cifrado: ¿AES por archivo?, ¿cómo se genera y protege la clave?, ¿RSA embebido? Documenta el esquema.
7. Evalúa la recuperación: ¿clave reutilizada?, ¿IV predecible?, ¿nota con ID de víctima? Contrasta con No More Ransom.
8. Extrae la nota de rescate y los IOCs; mapea la cadena a ATT&CK. Restaura `base-clean` .

Ejercicios

1. Explica el cifrado híbrido y por qué hace inviable descifrar sin la clave privada.
2. Detecta y documenta los comandos de borrado de shadow copies.
3. Analiza una nota de rescate e infiere la familia.
4. Propón 3 controles preventivos priorizados (backups, EDR, segmentación).
5. Reconoce señales de exfiltración previa al cifrado.
6. Diseña una detección temprana basada en el patrón de escritura masiva.

Reto verificable

Entrega un **informe de ransomware** con: cadena de ataque mapeada a ATT&CK, esquema de cifrado descrito, evidencia de borrado de backups, veredicto de recuperabilidad justificado e IOCs (incl. nota y extensión). **Criterio de aceptación:** el informe justifica con evidencia si el descifrado sin clave es posible, y la cadena incluye al menos las fases de ejecución, evasión (`T1490`) e impacto (`T1486`).

⚠ Errores comunes

Síntoma / mensaje	Causa y cómo arreglar
Cifra el host de análisis	Carpeta compartida activa; aíslala y restaura snapshot
"Es descifrable" sin pruebas	Verifica el esquema real; el híbrido correcto no lo es
Ignorar la exfiltración	Revisa tráfico previo al cifrado; hay doble extorsión
No ver el borrado de VSS	Filtra procesos hijos <code>vssadmin</code> / <code>wmic</code> en ProcMon
Confundir familia por la extensión	La extensión puede variar; correlaciona con la nota y TTPs

? Preguntas frecuentes

? **¿Se puede descifrar sin pagar?** A veces: si hay errores criptográficos, claves filtradas o descifradores públicos (No More Ransom). Con cifrado híbrido bien hecho y backups destruidos, normalmente no.

? **¿Por qué borran las shadow copies?** Para impedir la recuperación local de Windows y forzar el pago.

? **¿El cifrado es lo primero que ocurre?** No. Suele ser la fase final; antes hay acceso, escalada, movimiento lateral y exfiltración. Detectar temprano evita el cifrado.

🔗 Referencias

- Monnappa K. A., *Learning Malware Analysis*.
- The DFIR Report. <https://thedfirreport.com>
- No More Ransom. <https://www.nomoreransom.org>
- MITRE ATT&CK — Data Encrypted for Impact (T1486). <https://attack.mitre.org/techniques/T1486/>

➡ Siguiente clase

Clase 151 - Rootkits y bootkits